

CS 03506

CYBERSECURITY MANAGEMENT, POLICY, AND RISK

AUDIT & RISK ASSESSMENT PLAN

Group Members:	Dinos Klentzeris Gabriel Montes Devon Jacob
Instructor:	Sally Tarabah
Date:	09/27/2024

CYBER SECURITY CONTROLS CHECKLIST

PERSONAL SECURITY	Yes	No
1. Does Staff wear ID badges?	☐	☒
2. Do you check the credentials of external contractors?	☒	☐
3. Do you have policies addressing background checks for employees and contractors?	☒	☐
4. Do you have a process for effectively cutting off access to facilities and information systems when an employee/contractor terminates employment?	☒	☐
PHYSICAL SECURITY	Yes	No
5. Are there policies and procedures that address allowing authorized and limiting unauthorized physical access to electronic information systems and the facilities in which they are housed?	☒	☐
6. Do your policies and procedures specify the methods used to control physical access to your secure areas, such as door locks, access control systems, security officers, or video monitoring?	☒	☐
7. Is access to your computing area controlled (single point, reception or security desk, sign-in/sign-out log, temporary/visitor badges)?	☒	☐
8. Are visitors escorted into and out of controlled areas?	☐	☒
9. Are your PCs inaccessible to unauthorized users (e.g. located away from public areas)?	☒	☐
10. Are there procedures in place to prevent computers from being left in a logged-on state, however briefly?	☒	☐
11. Are screens automatically locked after 10 minutes idle?	☒	☐
12. Do you have procedures for protecting data during equipment repairs?	☒	☐
13. Do you have policies covering laptop security (e.g. cable lock or secure storage)?	☐	☒
14. Is there an emergency evacuation plan and is it current?	☒	☐
15. Does your plan identify areas and facilities that need to be sealed off immediately in case of an emergency?	☐	☒
ACCOUNT AND PASSWORD MANAGEMENT	Yes	No
16. Are there measures in place to ensure that only authorized personnel have access to your computers?	☒	☐

17. Do you require and enforce appropriate passwords?	☒	☐
18. Are your passwords secure (not easy to guess, regularly changed, no use of temporary or default passwords)?	☒	☐
19. Are computers set up so others cannot view staff entering passwords?	☒	☐
CONFIDENTIALITY OF SENSITIVE DATA	Yes	No
20. Do you classify your data, identifying sensitive data versus non sensitive?	☒	☐
21. Are you exercising responsibilities to protect sensitive data under your control?	☒	☐
22. Is the most valuable or sensitive data encrypted?	☒	☐
23. Do you have a policy for identifying the retention of information (both hard and soft copies)?	☐	☒
24. Do you have procedures in place to deal with credit card information?	☒	☐
25. Do you have procedures covering the management of personal private information?	☒	☐
26. Is there a process for creating retrievable backup and archival copies of critical information?	☐	☒
27. Do you have procedures for disposing of waste material?	☒	☐
28. Is wastepaper binned or shredded?	☒	☐
29. Is your shredded bin always locked?	☐	☒
30. Do your policies for disposing of old computer equipment protect against loss of data (e.g. by reading old disks and hard drives)?	☒	☐
31. Do your disposal procedures identify appropriate technologies and methods for making hardware and electronic media unusable and inaccessible (such as shredding CDs and DVDs, electronically wiping drives, burning tapes) etc.)?	☒	☐
DISASTER RECOVERY	Yes	No
32. Do you have a current Business Continuity Plan (BCP)?	☒	☐
33. Do you have an emergency/incident management communications plan?	☐	☒
34. Do you have a procedure for notifying authorities in the case of a disaster or security incident?	☒	☐

35. Does your procedure identify who should be contacted, including contact information?	☒	☐
36. Is the contact information sorted and identified by incident type?	☒	☐
37. Does your procedure identify who should make the contacts?	☐	☒
38. Have you identified who will speak to the press/public in the case of an emergency or an incident?	☐	☒
39. Does your communications plan cover internal communications with your employees and their families?	☐	☒
40. Can emergency procedures be appropriately implemented, as needed, by those responsible?	☒	☐
SECURITY AWARENESS AND EDUCATION	Yes	No
41. Are you providing information about computer security to your staff?	☒	☐
42. Do you provide training on a regular recurring basis?	☒	☐
43. Are employees taught to be alert to possible security breaches?	☒	☐
44. Are your employees taught about keeping their passwords secure?	☒	☐
45. Are your employees able to identify and protect classified data, including paper documents, removable media, and electronic documents?	☒	☐
46. Does your awareness and education plan teach proper methods for managing credit card data (PCI standards) and personal private information (Social security numbers, names, addresses, phone numbers, etc.)?	☒	☐
COMPLIANCE AND AUDIT	Yes	No
47. Do you review and revise your security documents, such as: policies standards, procedures, and guidelines, on a regular basis?	☒	☐
48. Do you audit your processes and procedures for compliance with established policies and standards?	☒	☐
49. Do you test your disaster plans on a regular basis?	☐	☒
50. Does management regularly review lists of individuals with physical access to sensitive facilities or electronic access to information systems?	☒	☐

CHECKLIST RESPONSE ANALYSIS

Question: Does Staff wear ID badges? No

At Green Foods Market staff are not required to wear ID badges given the small team of five employees and seasonal staff. Employees familiar with each other reduces the need for formal identification.

Question: Are visitors escorted into and out of controlled areas? No

No, visitors are not currently escorted in and out of Green Foods Market, as it is a relatively small organization without security personnel or a front desk receptionist. However, they must be granted access into the secure working area by an employee.

Question: Do you have policies covering laptop security (e.g. cable lock or secure storage)? No

In our organization, employees use company-provided desktop computers to perform their work. However, in the future should laptops be introduced into the company security measures should be implemented to secure them.

Question: Does your plan identify areas and facilities that need to be sealed off immediately in case of an emergency? No

Aside from areas that must always remain locked to the public (such as the computer room), all emergency protocol requires building occupants to evacuate immediately without securing any part of the building.

Question: Do you have a policy for identifying the retention of information (both hard and soft copies)? No

Data is backed up in the cloud by the IT contractors, who have rudimentary data retention policies, but the company itself has no policy on identifying information retention.

Question: Is there a process for creating retrievable backup and archival copies of critical information? No

All data is backed up to the cloud, providing a level of redundancy and accessibility. However, there are currently no local backups in place for critical information, which poses a risk in the event of internet outages or cloud service disruptions.

Question: Is your shredded bin always locked? No

No, the shredder bin is not always locked; however, it is in a secure and restricted area that is accessible only to authorized personnel.

Question: Do you have an emergency/incident management communications plan? No

The company does not have an emergency/incident management communications plan, as it is a small organization and does not designate specific individuals for communication during incidents or emergencies.

Question: Does your procedure identify who should make the contacts? No

No, the current procedure does not specify who should be responsible for making contact during an incident or emergency. There is no specific roles or responsibilities for communication during an incident or emergency

Question: Have you identified who will speak to the press/public in the case of an emergency or an incident? No

The company has not designated anyone to speak to the press or public in the event of an emergency or incident. As a small organization with limited staff, Green Foods Market does not currently have specific roles assigned for this purpose.

Question: Does your communications plan cover internal communications with your employees and their families? No

Since there is no communication plan, internal communication between employees and their families is not clearly defined. However, in such incidents, it will likely be handled by the owner or manager.

Question: Do you test your disaster plans on a regular basis? No

The company does not currently conduct regular tests of its disaster plans because of limited staff and a focus on prioritizing daily essential tasks.

CYBER SECURITY THREAT/VULNERABILITY ASSESSMENT

NATURAL THREATS		
Storm Damage (Hurricane/ Flooding)	Fire	Lightning Strikes
HUMAN THREATS		
Unauthorized Access	Fraud	Theft
Hacking	Spoofing	System Tampering
Negligence or Human Error	Social Engineering and Impersonation	Sabotage or Vandalism
Malicious Software Installation	Physical Security Breach	Credential Theft
ENVIRONMENTAL THREATS		
Long-term power outages		

For this assessment, numeric rating scales are used to establish impact potential (0-5) and likelihood probability (0-5).

IMPACT SCALE (0-5)	
0	Impact is negligible
1	Minor, major operations not affected
2	Organization operations are unavailable for a certain amount of time, costs are incurred. Public/customer confidence is minimally affected
3	Significant loss of operations, significant impact on public/customer confidence.
4	Effect is disastrous, systems are down for an extended period, systems need to be rebuilt, and data replaced
5	Effect is catastrophic, critical systems are offline for an extended period; data are lost or irreparably corrupted; public health and safety are affected

LIKELIHOOD SCALE (0-5)	
0	Unlikely to occur
1	Likely to occur less than once per year
2	Likely to occur once per year
3	Likely to occur once per month
4	Likely to occur once per week
5	Likely to occur daily

Threats caused by humans are capable of significantly impairing the ability for an organization to operate effectively. Human threats sources at Green Foods Market include:

SOURCE	SOURCE DESCRIPTION
Insiders	Employees, owner/manager, seasonal staff
General contractors and subcontractors	IT support, Website support
Former employees	Employees who have retired, resigned, or were terminated
Unauthorized users	Computer criminals, unauthorized access, and intruders (hackers and crackers) who attempt to access sensitive data

The following formula is used to calculate the risk score:

RISK = IMPACT x LIKELIHOOD

The table below is used to assess the risk level of each threat or vulnerability based on the calculated risk score.

SCORE	RISK LEVEL	RISK OCCURRENCE LEVEL
21 – 30	High Risk	Occurrence may result in significant loss of major tangible assets, information, or information resources. May significantly disrupt the organization's operations or seriously harm its reputation.
11 – 20	Medium Risk	Occurrence may result in some loss of tangible assets, information, or information resources. May disrupt or harm the organization's operation or reputation. For example, authorized users can't access supportive data for several days
1 – 10	Low Risk	Occurrence may result in minimal loss of tangible assets, information, or information resources. May adversely affect the organization's operation or reputation. For example, authorized users aren't granted access to supportive data for an hour

CYBER SECURITY THREAT/VULNERABILITY ASSESSMENT

HUMAN THREATS	Impact (0-5)	Probability (0-5)	Score (Impact x Probability)
1. Human Error			
• Accidental destruction, modification, or incorrect classification of information	4	2	8
• Ignorance: Lack of knowledge and lack of security awareness	3	3	9
• Workload: Too many or too few system administrators, highly pressured users	3	3	9
• Users may inadvertently give information on security weaknesses to attackers	4	3	12
• Incorrect system configuration	3	4	12
• Security policy not adequate	2	2	4
• Security policy not enforced	3	4	12
• Security analysis may have omitted something important or be wrong	5	2	10
2. Dishonesty			
• Fraud, theft, or embezzlement	4	2	8
3. Social Engineering Attacks			
• Attackers may use telephone to impersonate employees	4	3	12
• Attackers may persuade users to execute Trojan Horse programs	4	3	12
4. Abuse of privilege	3	2	6
GENERAL THREATS	Impact (0-5)	Probability (0-5)	Score (Impact x Probability)
1. Unauthorized use of open computers	4	2	8
2. Introduction of unauthorized software or hardware	2	1	2

3. Operating system design errors: Certain systems were not designed to be highly secure	3	2	6
4. Protocol design errors: Certain protocols were not designed to be highly secure. Protocol weaknesses in TCP/IP can result in:	3	1	3
Source routing, DNS spoofing, TCP sequence guessing, unauthorized access	4	2	8
Hijacked sessions and authentication session/transaction replay, data is changed or copied during transmission	4	2	8
Denial of service, due to ICMP bombing, TCP-SYN flooding, large PING packets, etc.	3	2	6
5. Logic bomb: Software programmed to damage a system under certain conditions	4	2	8
6. Viruses in programs, documents, e-mail attachments	4	3	12
IDENTIFICATION AUTHORIZATION THREATS	Impact (0-5)	Probability (0-5)	Score (Impact x Probability)
1. Attack programs masquerading as normal programs (Trojan horses).	4	2	8
2. Attack hardware masquerading as normal commercial hardware	3	2	6
3. External attackers masquerading as valid users or customers	4	3	12
4. Internal attackers masquerading as valid users or customers	4	2	8
5. Attackers masquerading as helpdesk/support personnel	4	3	12
PRIVACY THREATS	Impact (0-5)	Probability (0-5)	Score (Impact x Probability)
1. Eavesdropping	1	4	4
Electromagnetic eavesdropping / Ban Eck radiation	3	1	3
Telephone/fax eavesdropping (via “clip-on” telephone bugs, inductive sensors, or hacking the public telephone exchanges	3	1	3

• Network eavesdropping. Unauthorized monitoring of sensitive data crossing the internal network, unknown to the data owner	3	1	3
• Subversion of ONS to redirect email or other traffic	4	1	4
• Subversion of routing protocols to redirect email or other traffic	3	1	3
• Radio signal eavesdropping.	2	1	2
• Rubbish eavesdropping (analyzing waste for confidential documents, etc.)	1	0	0
INTEGRITY / ACCURACY THREATS	Impact (0-5)	Probability (0-5)	Score (Impact x Probability)
1. Malicious, deliberate damage of information or information processing functions from external sources	4	2	8
2. Malicious, deliberate damage of information or information processing functions from internal sources	3	2	6
3. Deliberate modification of information	3	3	9
ACCESS CONTROL THREATS	Impact (0-5)	Probability (0-5)	Score (Impact x Probability)
1. Password cracking (access to password files, use of bad – blank, default, rarely changed – passwords)	3	3	6
2. External access to password files, and sniffing of the networks	4	3	12
3. Attack programs allowing external access to systems (back doors visible to external networks)	3	3	9
4. Attack programs allowing internal access to systems (back doors visible to internal networks)	3	3	9
5. Unsecured maintenance modes, developer backdoors	4	1	4
6. Modems easily connected, allowing uncontrollable extension of the internal network	3	2	6
7. Bugs in network soft are which can open unknown/unexpected security holes	3	2	6

8. Unauthorized physical access to system	4	2	8
REPUDIATION THREAT	Impact (0-5)	Probability (0-5)	Score (Impact x Probability)
1. Receivers of confidential information may refuse to acknowledge receipt	3	1	3
2. Senders of confidential information may refuse to acknowledge source	3	1	3
LEGAL THREATS	Impact (0-5)	Probability (0-5)	Score (Impact x Probability)
1. Failure to comply with regulatory or legal requirements (i.e., to protect confidentiality of employee data)	4	2	8
2. Liability for damages if an internal user attacks other sites.	3	2	6
RELIABILITY OF SERVICE THREATS	Impact (0-5)	Probability (0-5)	Score (Impact x Probability)
1. Major natural disasters, fire, smoke, water, earthquake, storms/hurricanes/tornadoes, power outages, etc.	5	1	5
2. Minor natural disasters, of short duration, or causing little damage	4	2	8
3. Equipment failure from defective hardware, cabling, or communications system.	4	3	12
4. Denial of Service:			
• Network abuse: Misuse of routing protocols to confuse and mislead systems	4	2	8
• Server overloading (processes, swap space, memory, “tmp” directories, overloading services	3	1	3
• Email bombing	3	2	6
• Downloading or receipt of malicious Applets, Active X controls, macros, PostScript files, etc.	3	1	3
5. Sabotage: Malicious, deliberate damage of information or information processing functions.			

Physical destruction of network interface devices, cables	4	2	8
Physical destruction of computing devices or media	4	1	4
Deliberate electrical overloads or shutting off electrical power	4	1	4
Viruses and/or worms. Deletion of critical systems files	4	1	4

This table is an extract from the table above reflecting only high-risk threats and vulnerabilities.

HUMAN THREATS	Score (Impact x Probability)
1. Users may inadvertently give information on security weaknesses to attackers	12
2. Incorrect system configuration	12
3. Security policy not enforced	12
4. Security analysis may have omitted something important or be wrong	10
5. Attackers may use telephone to impersonate employees	12
6. Attackers may persuade users to execute Trojan Horse programs	12
GENERAL THREATS	Score (Impact x Probability)
7. Viruses in programs, documents, e-mail attachments	12
IDENTIFICATION AUTHORIZATION THREATS	Score (Impact x Probability)
8. External attackers masquerading as valid users or customers	12
9. Attackers masquerading as helpdesk/support personnel	12
ACCESS CONTROL THREATS	Score (Impact x Probability)
10. External access to password files, and sniffing of the networks	12
RELIABILITY OF SERVICE THREATS	Score (Impact x Probability)
11. Minor natural disasters, of short duration, or causing little damage	12

RECOMMENDED SECURITY RISK REMEDIATION ACTIONS

The following table identifies a set of remediation activities designed to focus on the commonly identified High risk threats and vulnerabilities. Actions are ranked in priority order of effectiveness.

No.	Remediation Action – Human Threats	Cost	Benefits	Risk
1	Implement regular security awareness programs to educate staff on security best practices.	Low	High	High
2	System administrators should receive training on secure configuration settings that adheres to the company policy.	Low	High	High
3	Staff should receive regular reminders about the company's security policies, and management should enforce these policies to ensure compliance among employees.	Low	High	High
4	A comprehensive review process should be implemented for security analysis to ensure it was conducted thoroughly.	Low	High	High
5	Staff must limit the amount of sensitive information shared over the phone unless caller identity is certainly verified.	Low	High	High
6	User account privileges to install software on company devices should be strictly prohibited.	Low	High	High
No.	Remediation Action – General Threats	Cost	Benefits	Risk
7	Antivirus and anti-malware software should always be installed and updated to detect and prevent viruses.	Low	High	High
No.	Remediation Action – Identification Authorization Threat	Cost	Benefits	Risk
8	All employees should have multi-factor authentication (MFA) enable on their account to prevent attackers	Low	High	High
9	Strict verification protocol should be implemented to verify identity of helpdesk or support staff.	Low	High	High
No.	Remediation Action – Access Control Threats	Cost	Benefits	Risk
11	Strict encryption should be implemented to protect password and sensitive data being transmitted over the network.	Moderate	High	High
No.	Remediation Action – Reliability of Service Threat	Cost	Benefits	Risk
12	Data should be backed up regularly to prevent data loss caused due to minor disasters.	Moderate	High	High

Work Cited

“BRUCyberSecurityChecklist.Pdf.” *Google Drive*, Google,
drive.google.com/file/d/10MWe1IFUDb5vkazbRZdx7Lx-F7Ncsf_1/view. Accessed 27 Sept. 2024.